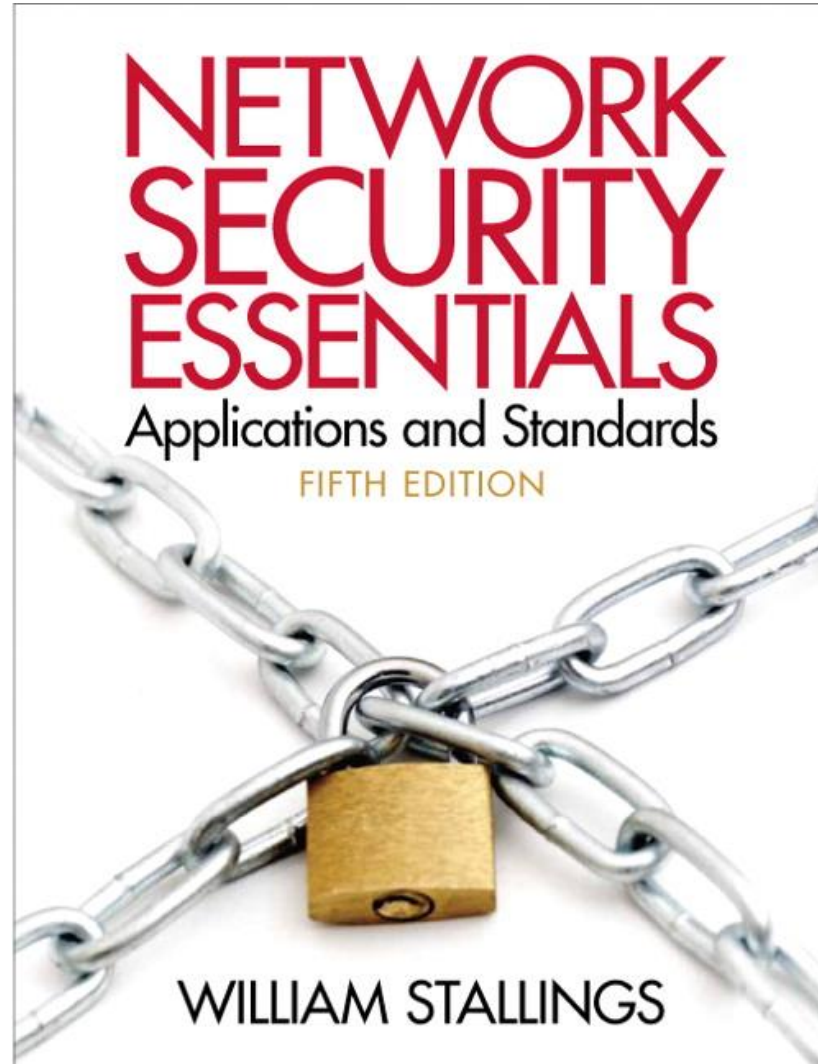




# FIREWALLS

Types and Configurations





# Network Security Essentials

Fifth Edition

by William Stallings



# Firewalls

*(A perimeter protection)*

Internet connectivity is no longer optional for organizations

- Individual users within the organization want and need Internet access

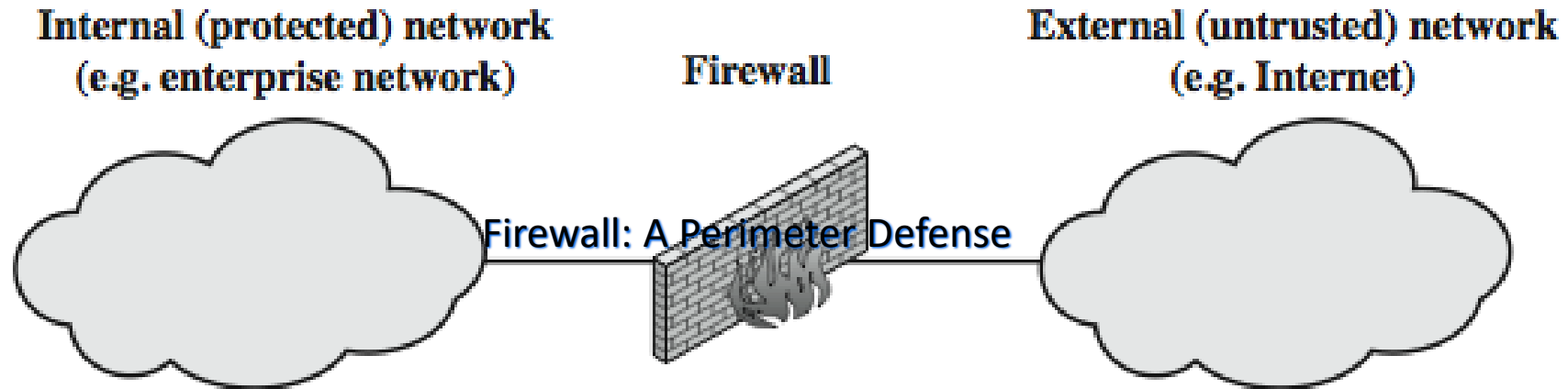
While Internet access provides benefits to the organization, it enables the outside world to reach and interact with local network assets

- This creates a threat to the organization
- While it is possible to equip each workstation and server on the premises network with strong security features, this may not be sufficient and in some cases is not cost-effective

## Firewall

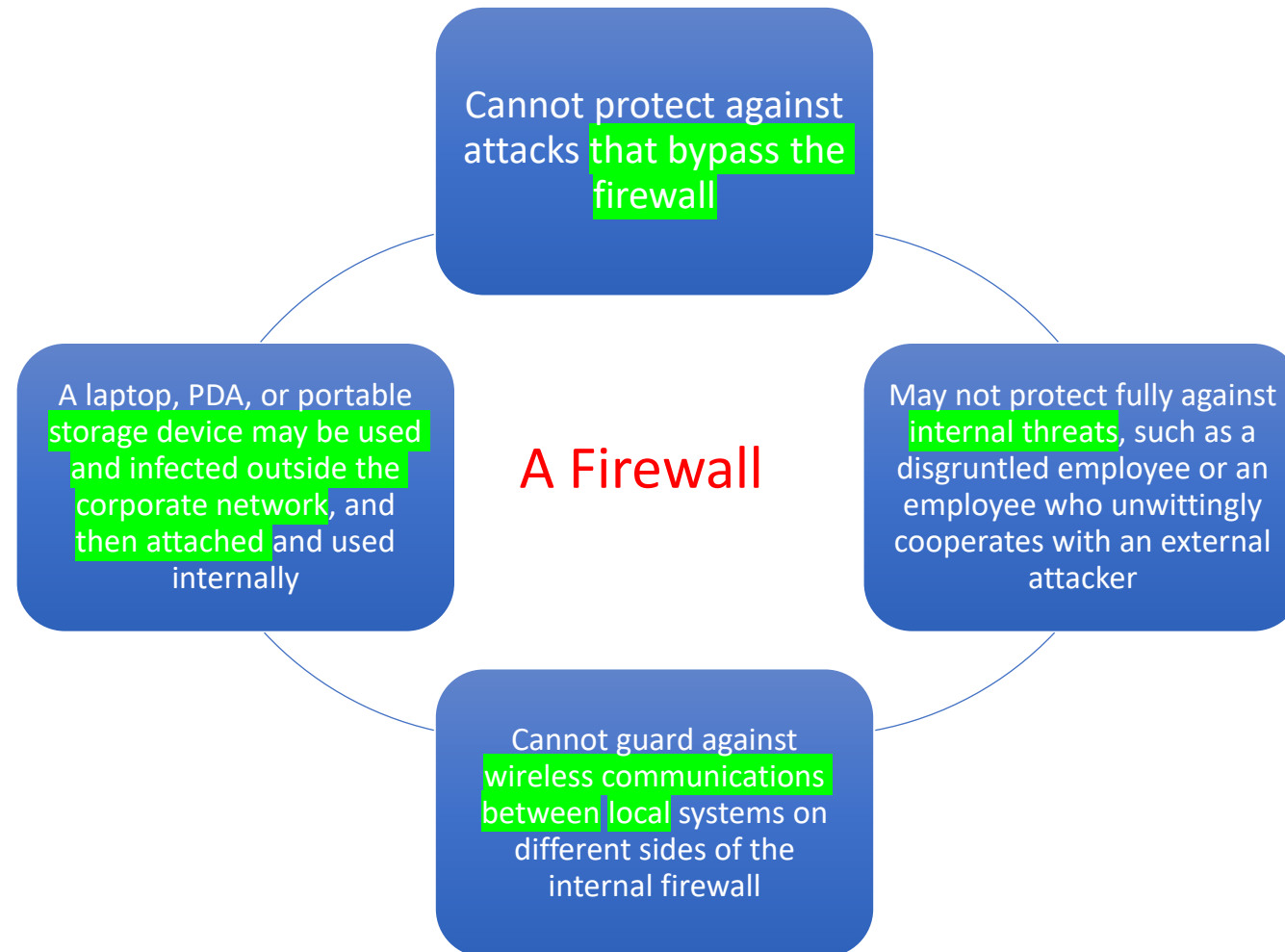
- An alternative, or at least complement, to **host-based security services**
- **Is inserted between the premises and the Internet** to establish a controlled link and to erect an outer security wall or perimeter
- The aim of this perimeter is to protect the premises network from Internet-based attacks and to provide a single choke point where security and auditing can be imposed
- May be a single computer system or a set of two or more systems that cooperate to perform the firewall function

# What is a Firewall?



A general model of firewall use on the security perimeter, as a choke point for traffic between the external less-trusted Internet and the internal more trusted private network.

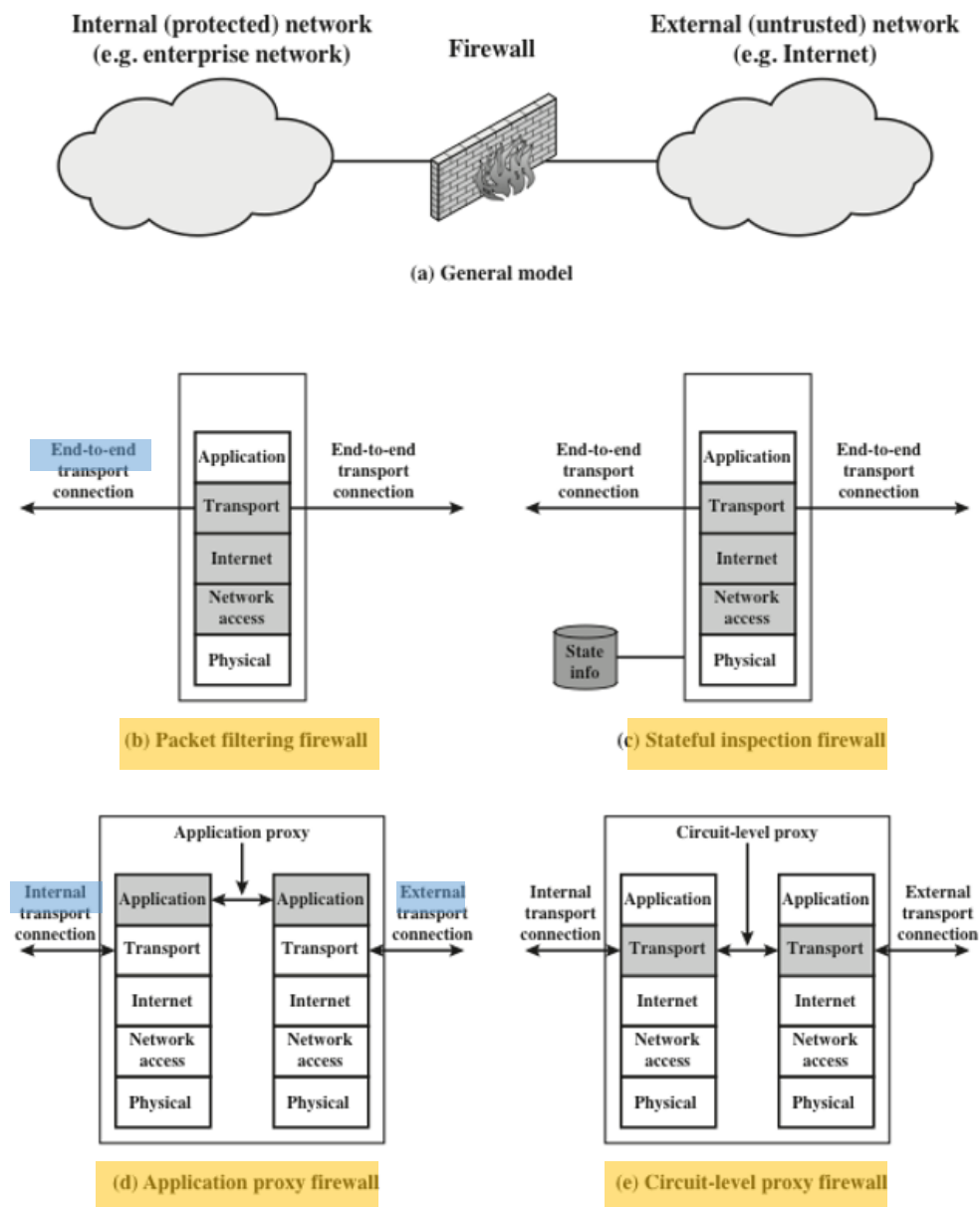
# Firewall limitations





# Types of Firewalls

(Figure 12.1)



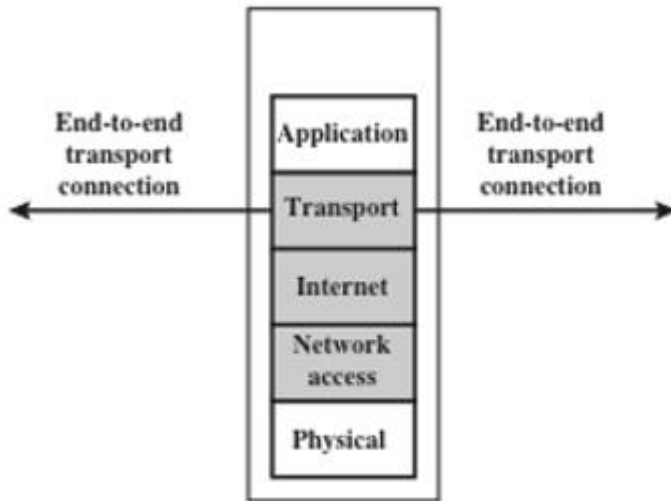


# Packet Filtering Firewall

A packet filtering firewall applies a set of rules to **each incoming and outgoing IP packet** and then forwards or discards the packet.

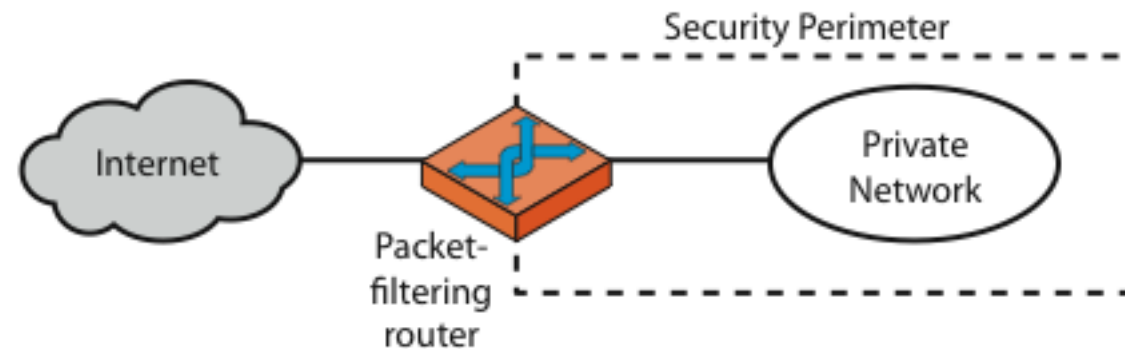
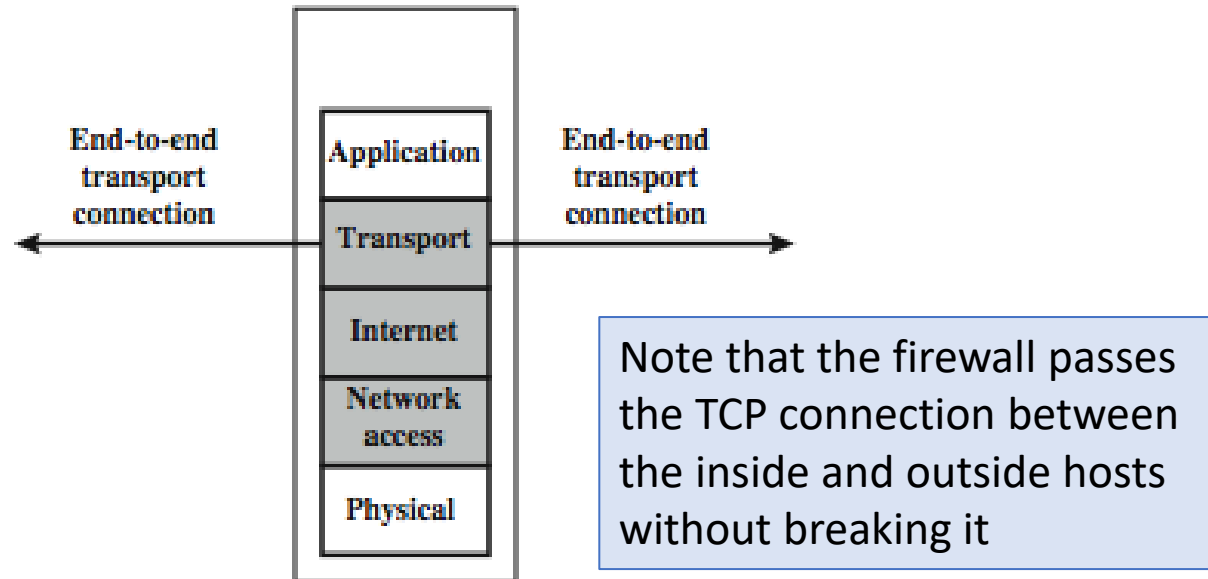
The firewall is typically configured to **filter packets going in both directions** (from and to the internal network). Filtering rules are based on information contained in a network packet:

- Source IP address: The IP address of the system that originated the IP packet (e.g., 192.178.1.1)
- Destination IP address: The IP address of the system the IP packet is trying to reach (e.g., 192.168.1.2)
- Source and destination transport-level address: The transport-level (e.g., TCP or UDP) port number, which defines applications such as SNMP or TELNET
- IP protocol field: Defines the transport protocol



Packet filtering firewall

# Packet Filter Firewall



(a) Packet-filtering router



# Examples of Rules



## Packet Filter Firewall – General Rules

| Rule | Direction | Src address | Dest addresss | Protocol | Dest port | Action |
|------|-----------|-------------|---------------|----------|-----------|--------|
| A    | In        | External    | Internal      | TCP      | 25        | Permit |
| B    | Out       | Internal    | External      | TCP      | >1023     | Permit |
| C    | Out       | Internal    | External      | TCP      | 25        | Permit |
| D    | In        | External    | Internal      | TCP      | >1023     | Permit |
| E    | Either    | Any         | Any           | Any      | Any       | Deny   |



# Packet Filtering Firewall

## Weaknesses

- Because packet filter firewalls do not examine upper-layer data, they cannot prevent attacks that employ application-specific vulnerabilities or functions
- Because of the limited information available to the firewall, the logging functionality present in packet filter firewalls is limited
- Most packet filter firewalls do not support advanced user authentication schemes
- Packet filter firewalls are generally vulnerable to attacks and exploits that take advantage of problems within the TCP/IP specification and protocol stack
- Due to the small number of variables used in access control decisions, packet filter firewalls are susceptible to security breaches caused by improper configurations

## Strengths

- Its simplicity
- Transparent to users and are very fast



# Attacks and Countermeasures

## IP address spoofing

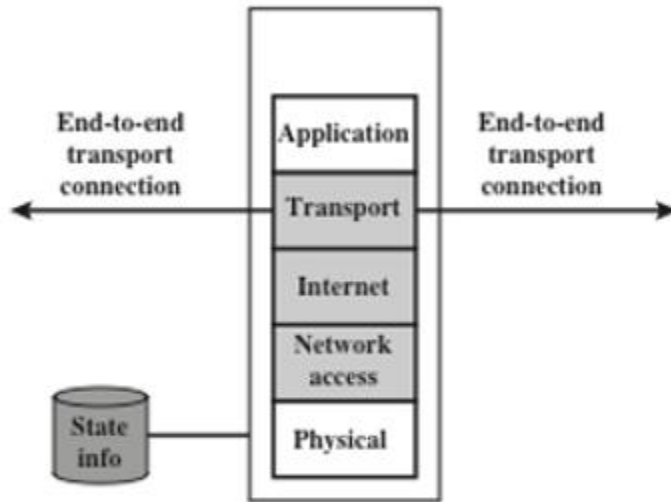
The intruder transmits packets from the outside with a source IP address field containing an address of an internal host

Countermeasure is to discard packets with an inside source address if the packet arrives on an external interface

## Tiny fragment attacks

The intruder uses the IP fragmentation option to create extremely small fragments and force the TCP header information into a separate packet fragment

Countermeasure is to enforce a rule that the first fragment of a packet must contain a predefined minimum amount of the transport header



Stateful inspection firewall

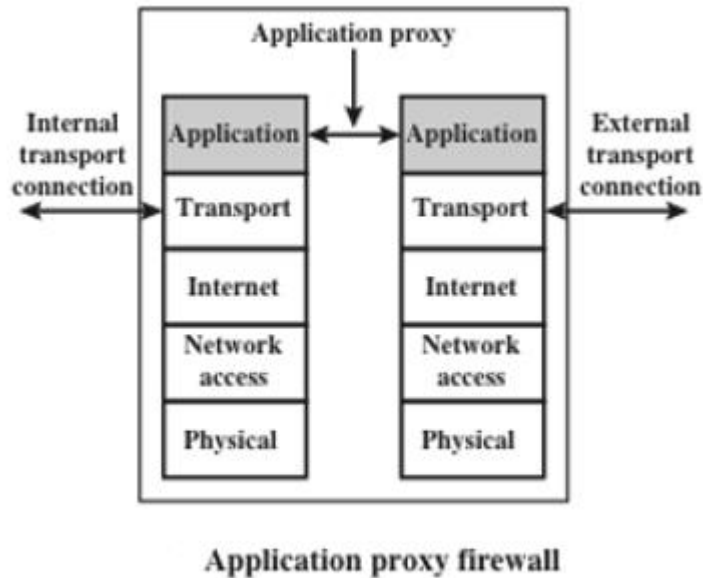
| Source Address | Source Port | Destination Address | Destination Port | Connection State |
|----------------|-------------|---------------------|------------------|------------------|
| 192.168.1.100  | 1030        | 210.22.88.29        | 80               | Established      |
| 192.168.1.102  | 1031        | 216.32.42.123       | 80               | Established      |
| 192.168.1.101  | 1033        | 173.66.32.122       | 25               | Established      |
| 192.168.1.106  | 1035        | 177.231.32.12       | 79               | Established      |
| 223.43.21.231  | 1990        | 192.168.1.6         | 80               | Established      |
| 2122.22.123.32 | 2112        | 192.168.1.6         | 80               | Established      |
| 210.922.212.18 | 3321        | 192.168.1.6         | 80               | Established      |
| 24.102.32.23   | 1025        | 192.168.1.6         | 80               | Established      |
| 223.21.22.12   | 1046        | 192.168.1.6         | 80               | Established      |

## Stateful Firewall

*Example for the Connection State Table*

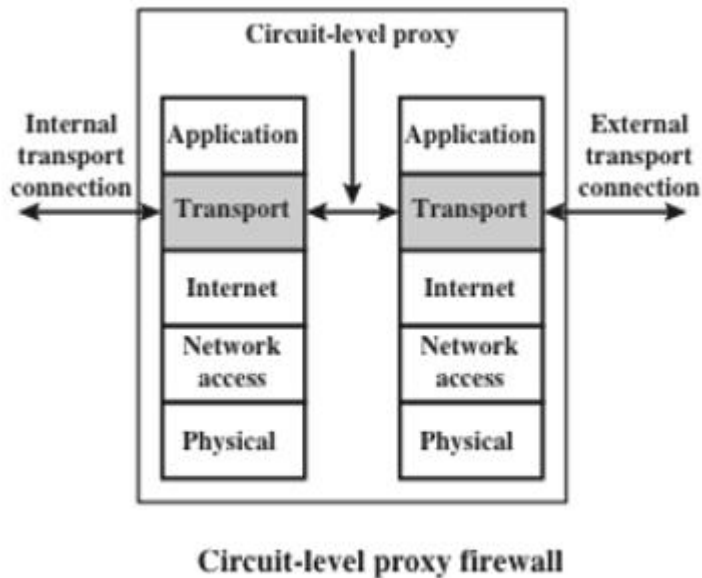


# Application Proxy Firewall



- ❑ Also called an *application proxy*
- ❑ Acts as a relay of application-level traffic
- ❑ If the gateway does not implement the proxy code for a specific application, the service is not supported and cannot be forwarded across the firewall
- ❑ The gateway can be configured to support only specific features of an application that the network administrator considers acceptable while denying all other features
- ❑ Tend to be more secure than packet filters
- ❑ Disadvantage: The additional processing overhead on each connection each application has a module

# Circuit-Level Proxy Firewall



Also called *circuit-level proxy*



Can be a stand-alone system or it can be a specialized function performed by an application-level gateway for certain applications



Does not permit an end-to-end TCP connection



The security function consists of determining which connections will be allowed



Typical use is a situation in which the system administrator trusts the internal users



Can be configured to support application-level or proxy service on inbound connections and circuit-level functions for outbound connections



Example of implementation is the SOCKS package



# The Bastion Host

A system identified by the firewall administrator as a critical strong point in the network's security

Typically serves as a platform for an application-level or circuit-level gateway

## Common characteristics:

- Executes a secure version of its operating system, making it a hardened system
- Only the services that the network administrator considers essential are installed
- May require additional authentication before a user is allowed access to the proxy services
- Each proxy is configured to support only a subset of the standard application's command set
- Each proxy is configured to allow access only to specific host systems
- Each proxy maintains detailed audit information by logging all traffic, each connection, and the duration of each connection
- Each proxy module is a very small software package specifically designed for network security
- Each proxy is independent of other proxies on the bastion host
- A proxy generally performs no disk access other than to read its initial configuration file
- Each proxy runs as a nonprivileged user in a private and secured directory on the bastion host

# Host-Based Firewall



- A software module used to secure an individual host
- Is available in many operating systems or can be provided as an add-on package
- Filters and restricts the flow of packets
- Common location is a server
- Advantages:
  - a) Filtering rules can be tailored to the host environment
  - b) Protection is provided independent of topology
  - c) Used in conjunction with stand-alone firewalls
  - d) Provides an additional layer of protection







# Personal Firewall



Controls the traffic between a personal computer or workstation on one side and the Internet or enterprise network on the other side



Can be used in the home environment and on corporate intranets



Typically is a software module on the personal computer



Can also be housed in a router that connects all of the home computers to a DSL, cable modem, or other Internet interface



Primary role is to deny unauthorized remote access to the computer



Can also monitor outgoing activity in an attempt to detect and block worms and other malware

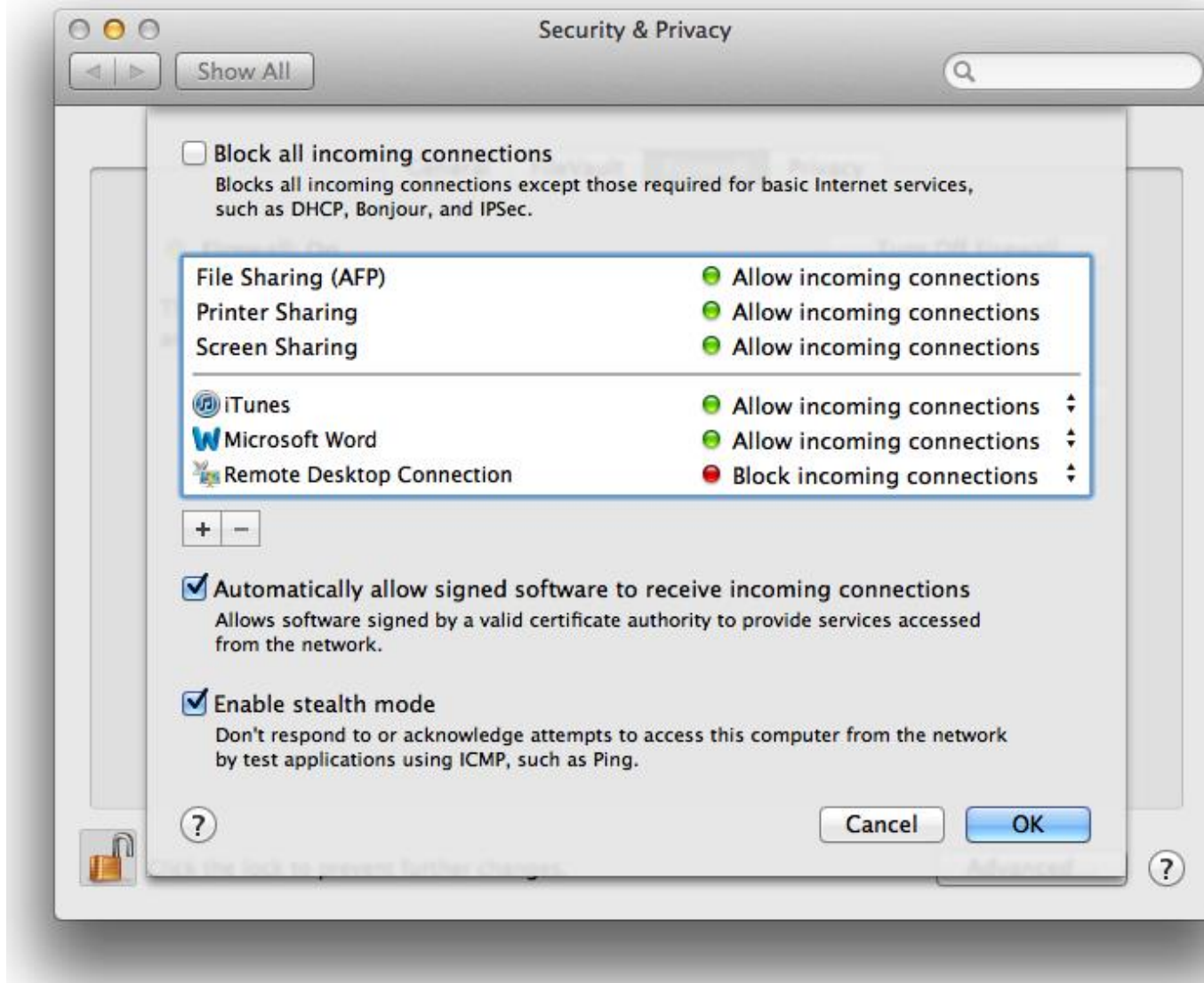


Figure 12.2  
Example Personal Firewall Interface

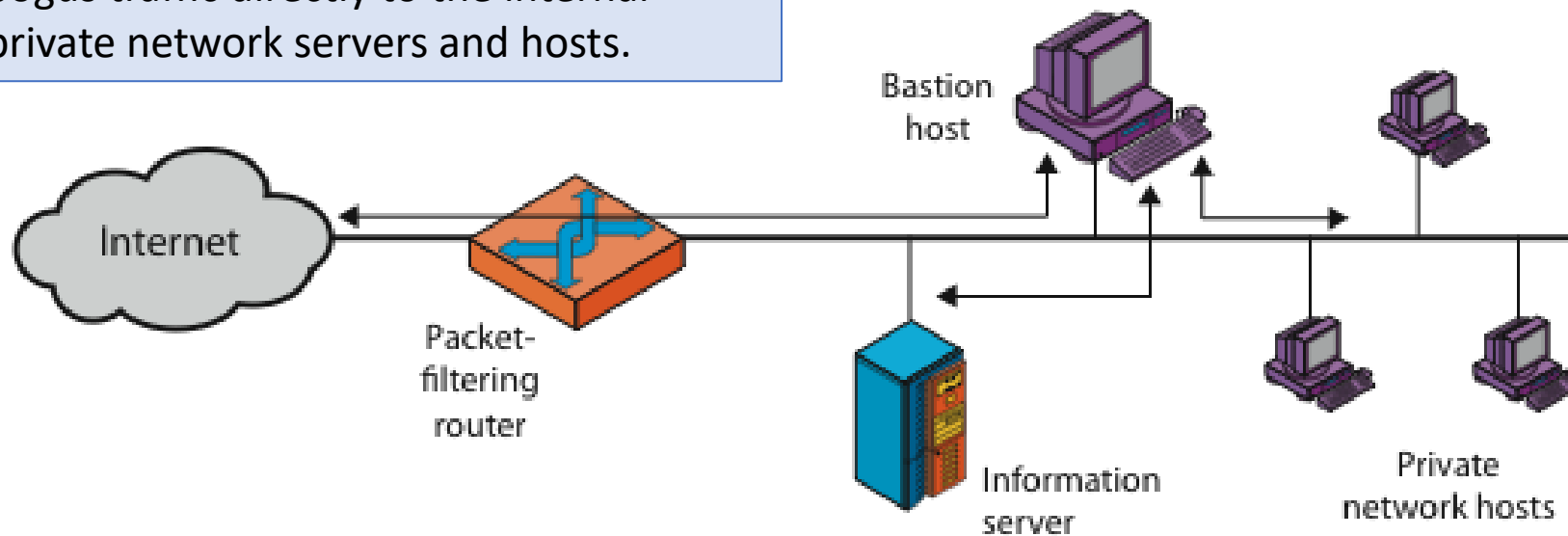
# EXAMPLE FIREWALL CONFIGURATIONS

# Firewall Configurations

- In general, a firewall is positioned to provide a protective barrier between an external, potentially untrusted source of traffic and an internal network. With that general principle in mind, a security administrator must decide on the location and on the number of firewalls needed.
- In addition to the use of a simple configuration consisting of a single system, more complex configurations are possible and indeed more common.

# 1) Single-Homed Bastion Host

Note that if an intruder compromises the packet-filtering router, he can by-pass the bastion host and pass any external bogus traffic directly to the internal private network servers and hosts.



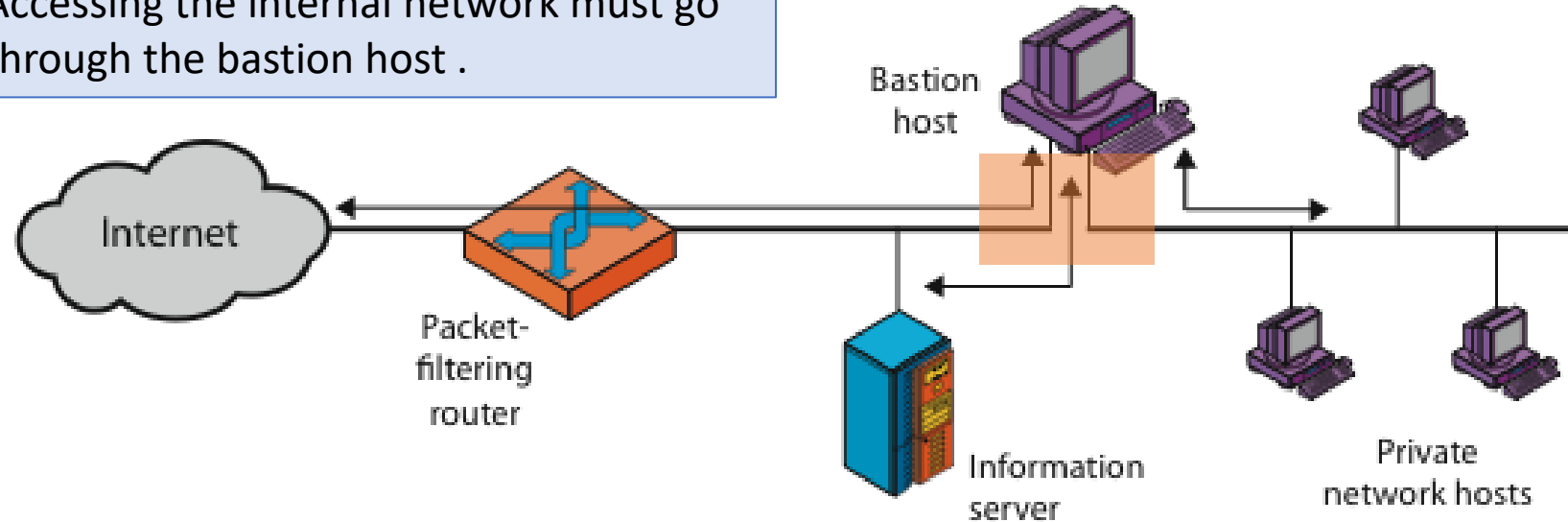
(a) Screened host firewall system (single-homed bastion host)

# Single-homed Bastion Host (SHBH)

- In the “screened host firewall, single-homed bastion configuration”, the firewall consists of two systems:
  - 1) a **packet-filtering router** - allows Internet packets to/from bastion only
  - 2) a **bastion host** - performs authentication and proxy functions
- This configuration has greater security, as it implements both **packet-level & application-level filtering**
- It forces an intruder to generally penetrate two separate systems to compromise internal security.
- It also affords flexibility in providing direct Internet access to specific internal servers (eg web) if desired

## 2) Dual-Homed Bastion Host

Note that if an intruder compromises the packet-filtering router, he must also compromise the bastion host to access the internal private network hosts. Accessing the internal network must go through the bastion host.



(b) Screened host firewall system (dual-homed bastion host)

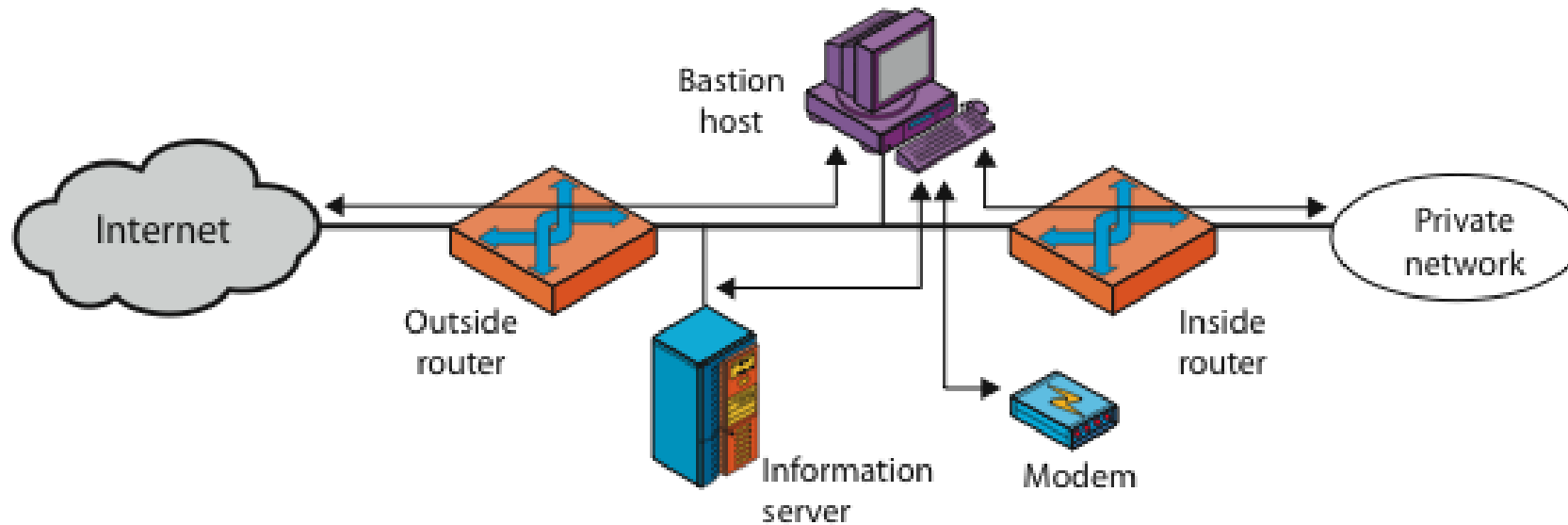
# Dual-homed Bastion Host (DHBH)

- This configuration physically separates the external and internal networks, ensuring two systems must be compromised to breach security.
- The advantages of dual layers of security are also present here.
- Again, an information server or other hosts can be allowed direct communication with the router if this is in accordance with the security policy, but are now separated from the internal network.



### 3) Screened Subnet Firewall

Both the Internet and the internal network have access to hosts on the screened subnet, but traffic across the screened subnet is blocked. There are now three levels of defense to thwart intruders



(c) Screened-subnet firewall system

# Screened Subnet Firewall (SSFW)

- This configuration is the most secure shown.
- It has two packet-filtering routers, one between the bastion host and the Internet and the other between the bastion host and the internal network, creating an isolated subnetwork (screened subnet).
- This screened subnet may consist of simply the bastion host but may also include one or more information servers and modems for dial-in capability.
- Typically, both the Internet and the internal network have access to hosts on the screened subnet, but traffic across the screened subnet is blocked.

# Screened Subnet Firewall (SSFW)

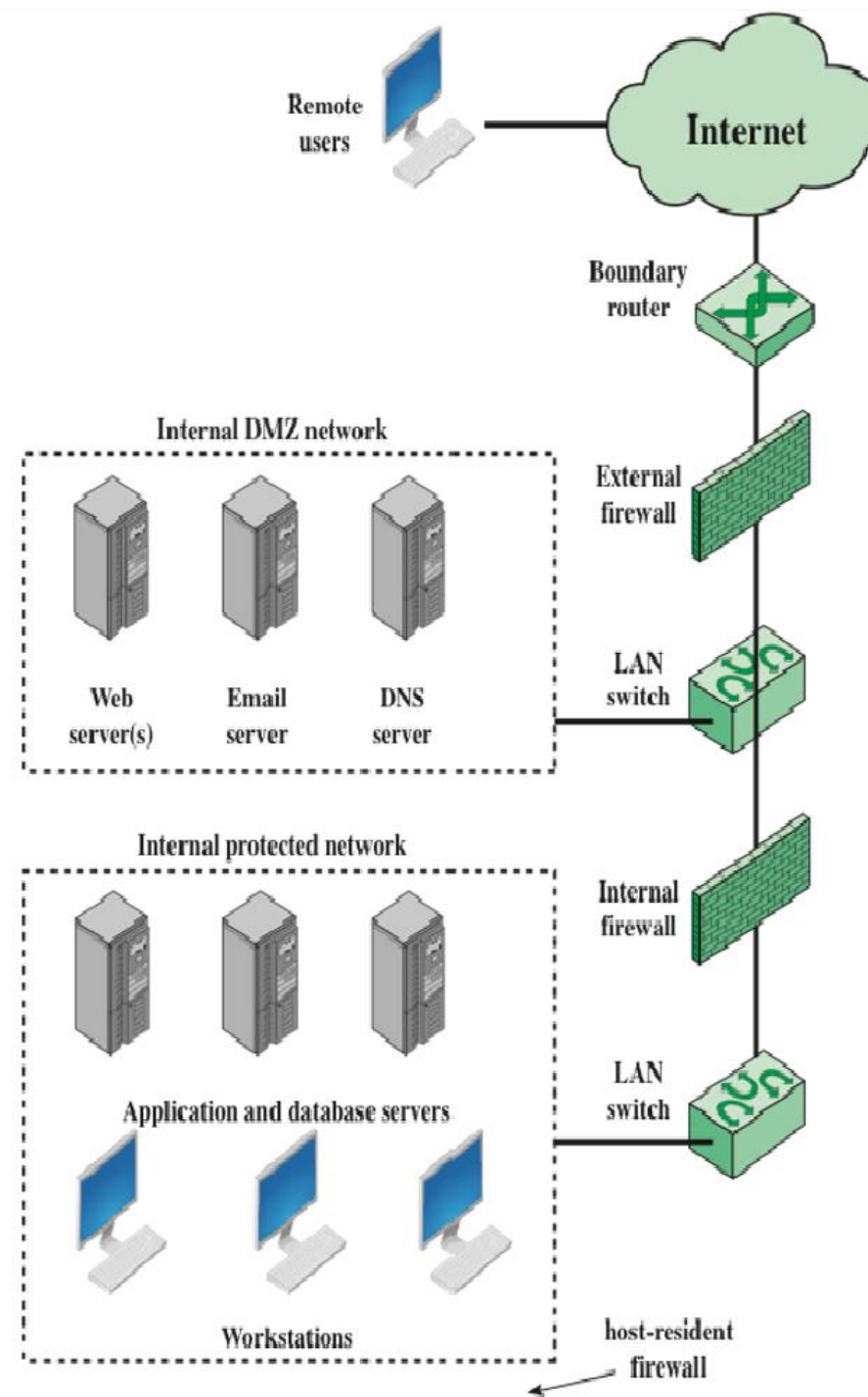
This configuration offers several advantages:

- 1) There are now three levels of defense to thwart intruders
- 2) The outside router advertises only the existence of the screened subnet to the Internet; therefore, the internal network is invisible to the Internet
- 3) Similarly, the inside router advertises only the existence of the screened subnet to the internal network; hence systems on the inside network cannot construct direct routes to the Internet



# DMZ Networks

The given figure suggests the most common distinction, that between an internal and an external firewall.



# DMZ Networks

This is a “screened subnet”, also known as a demilitarized zone (DMZ), located between an internal and an external firewall.

- An external firewall is placed at the edge of a local or enterprise network, just inside the boundary router that connects to the Internet or some wide area network (WAN).
- One or more internal firewalls protect the bulk of the enterprise network.

.

# DMZ Networks

- Systems that are externally accessible but need some protections are usually located on DMZ networks. Typically, the systems in the DMZ require or foster external connectivity, such as a corporate Web site, an e-mail server, or a DNS (domain name system) server.
- The external firewall provides a measure of access control and protection for the DMZ systems consistent with their need for external connectivity. The external firewall also provides a basic level of protection for the remainder of the enterprise network

# DMZ Networks

In this type of configuration, internal firewalls serve three purposes:

1. The internal firewall adds more stringent filtering capability, compared to the external firewall, to protect enterprise servers and workstations from external attack.
2. The internal firewall provides two-way protection with respect to the DMZ:
  - It protects the remainder of the network from attacks launched from DMZ systems.
  - It also protects DMZ systems from attack by internal hosts.
3. Multiple internal firewalls can be used to protect portions of the internal network from each other.

A common practice is to place the DMZ on a different network interface on the external firewall from that used to access the internal networks.



# VPN Security Scenario

In essence, a VPN uses encryption and authentication in the lower protocol layers to provide a secure connection through an otherwise insecure network, typically the Internet. VPNs are generally cheaper than real private networks using private lines but rely on having the same encryption and authentication system at both ends. The encryption may be performed by firewall software or possibly by routers.

The most common protocol mechanism used for this purpose is at the IP level and is known as **IPsec**.

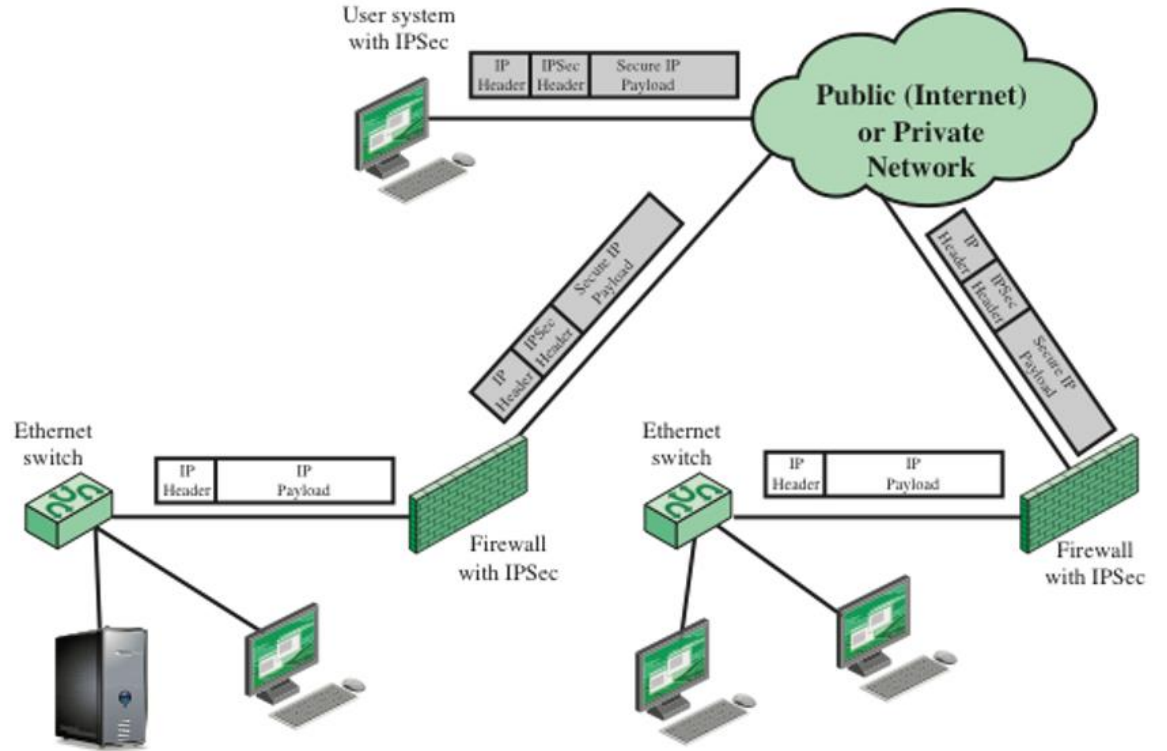


Figure 12.4 A VPN Security Scenario





# A Distributed Firewall Configuration

- External DMZ network
  - Internal DMZ network
  - Internal protected network
- A distributed firewall configuration involves stand-alone firewall devices plus host-based firewalls working together under a central administrative control.
  - Administrators can configure host-resident firewalls on hundreds of servers and workstations as well as configure personal firewalls on local and remote user systems. These firewalls protect against internal attacks and provide protection tailored to specific machines and applications.
  - Stand-alone firewalls provide global protection, including internal firewalls and an external firewall, as discussed previously.

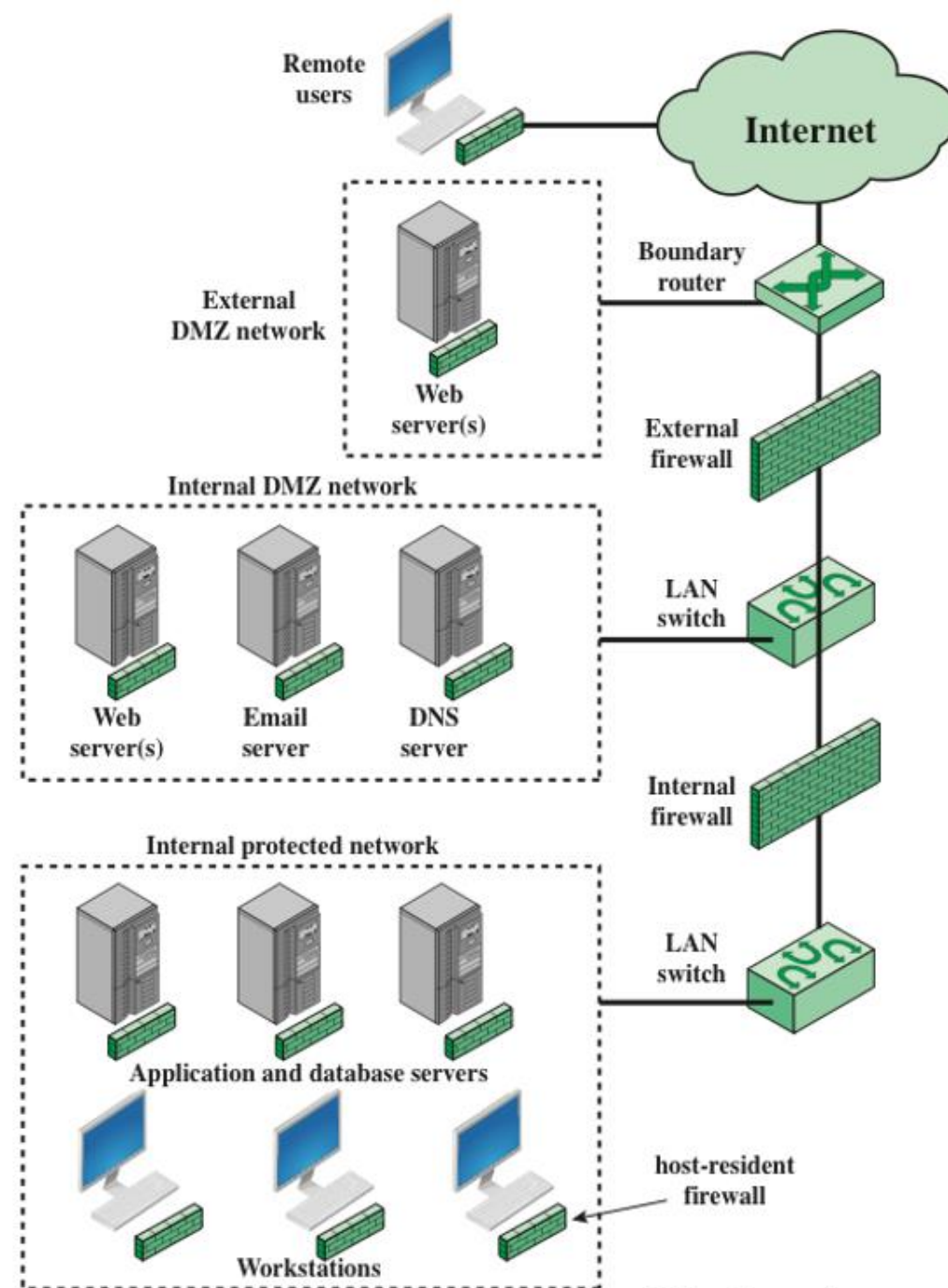


Figure 12.5 Example Distributed Firewall Configuration

# Summary of Firewall Locations and Topologies

- **Host-resident firewall**

This category includes personal firewall software and firewall software on servers

Can be used alone or as part of an in-depth firewall deployment

- **Screening router**

A single router between internal and external networks with stateless or full packet filtering

This arrangement is typical for small office/home office (SOHO) applications

- **Single bastion inline**

A single firewall device between an internal and external router

This is the typical firewall appliance configuration for small-to-medium sized organizations

- **Single bastion T**

Like single bastion inline but has a third network interface on bastion to a DMZ where externally visible servers are placed

- **Double bastion inline**

DMZ is sandwiched between bastion firewalls

- **Double bastion T**

DMZ is on a separate network interface on the bastion firewall

- **Distributed firewall configuration**

Used by some large businesses and government organizations

# Summary

- The need for firewalls
- Firewall characteristics
- Types of firewalls
  - 1- Packet filtering firewall
  - 2- Stateful inspection firewalls
  - 3- Application-level gateway
  - 4- Circuit-level gateway
- Firewall basing
  - 1- Bastion host
  - 2- Host based firewalls
  - 3- Personal firewall
- Firewall locations and configurations
  - 1- DMZ networks
  - 2- Virtual private networks
  - 3- Distributed firewalls
  - 4- Firewall location and topologies